事故一：白名单等于没防

案例来源： Anthropic 《 How we contain Claude across products 》复盘

事件背景

Claude Cowork 是装在电脑上的 AI 助手，需要访问 api.anthropic.com 才能连上自家服务器——这一地址被加入白名单。

攻击过程

攻击者在用户电脑的工作文件夹里放了一个看起来正常的文件，里面藏着恶意指令和一个偷来的 API key 。

Claude 读了文件以后“照做”——把工作区里的文件打包，用那把偷来的钥匙上传到了攻击者的账户。

出口检查一看：目标地址是 api.anthropic.com ，白名单里有，放行。文件到了攻击者手里。

沙箱（安全隔离区）完美工作，数据还是被偷了。

Anthropic 的总结

“ 白名单不是哪里能去的清单，而是给了 AI 多大的权力。允许一个网址，就等于允许这个网址背后的所有功能。”

事故二：用户自己就成了“病毒”

2026 年 2 月 Anthropic 内部模拟黑客攻击（红队演习）

事件经过

一个研究员给同事发了封邮件：“能帮我跑一下这个吗？”附件是看起来像正常工作指令的东西。

指令里悄悄混了一段：读取电脑里的 AWS 密钥文件（~/.aws/credentials），加密后发到外面某个网址。

25 次测试，AI 助手成功照做了 24 次。

为什么 AI 没有发现？

指令就是用户自己输入的。AI 的分类器（判断“这个请求安不安全”的模块）靠的是判断“用户有没有被操控”——这次用户确实是手动输入，分类器抓不到任何异常。

唯一能拦住这种情况的，是底层环境防御——直接禁止那个往外发数据的网络请求，或者让 ~/.aws 这个文件夹从一开始就不在 AI 能看到的地方。

细思极恐的细节

当团队把攻击指令发到内部聊天软件讨论时，有人指出公司内部的 AI 助手会读聊天记录——恶意指令已经在聊天环境里了。他们不得不在讨论群里加一个“蜜罐标记”，监测有没有 AI 助手不小心捡起这条消息。

Anthropic 三层防御：环境 > 模型 > 外部输入

AI 助手的安全不是“加几句提示词”就能搞定的

第一层：环境层——最硬，也最费功夫

核心思想不是“让 AI 变乖”，而是让 AI 根本碰不到不该碰的东西。三种隔离方案：

- 临时容器：代码跑在临时“盒子”里，用完清空；安全但只能简单聊天，适合网页聊天助手。
- 人工监督沙箱： AI 直接跑在你电脑上；但用户批准了 93% 的权限提示，加系统级安全隔离后审批减少 84% 。
- 完整虚拟机： AI 跑在完全隔离的“假电脑”里，只挂载选中的文件夹，密码永远不给它；但监控工具也进不去。

第三层：外部内容层

读网页、查数据库、连 GitHub 等插件入口都可能被“下毒”。做法：对所有外部内容实时检查，进入 AI 上下文之前用小模型做分类——会拖慢速度，也不是完美防御。

第二层：模型层——不是万能药

提示词、分类器、监控机制、训练全用上：最新版本在“被人骗”的测试中，单次攻击成功率只有 0.1% ， 100 次反复攻击后约 5-6% 。

但 Anthropic 说得很清楚：模型层永远不会 100% 有效——AI 不是确定的程序。两个最严重的事故，模型层都没帮上忙。

核心结论

三层缺一不可，环境层才是最后防线：确定性边界——系统隔离、白名单、虚拟机——是当所有概率性防御都失效时的兜底。

两个最严重的事故，本质都是同一个问题：数据通过一个“允许”的出口流走了。模型层抓不住，只有环境层能拦住。